CYPHER GROUP INC. · SIMULATED CASE STUDY

Cypher Group Inc. — Master Information Security Risk Register

Contents: 1. Risk scoring legend (read this before the register) · 2. THE MASTER RISK REGISTER · 3. Residual scoring rationale and control effectiveness · 4. Risk treatment plan · 5. Key risk indicators · 6. Register summary · 7. Methodology, limitations and honest caveats · 8. Approval

Assessed under NIST SP 800-30 Rev. 1, with control cross-references to the CGI-POL-001 to CGI-POL-005 policy pack

Field	Value
Document ID	CGI-RSK-001
Version	1.0
Classification	Confidential

> **All data in this register is simulated.** Cypher Group Inc. is a simulated company. This artefact demonstrates risk identification, scoring, control mapping and treatment decision-making.

Metadata block

Field	Value
Document ID	CGI-RSK-001
Document title	Master Information Security Risk Register
Version	1.0
Classification	Confidential
Register owner (accountable)	Priya Raman, Chief Technology Officer
Prepared by (assessor)	O.S, GRC Analyst (engaged)
Approved by	Jerry Gold, Chief Executive Officer
Assessment method	NIST SP 800-30 Rev. 1, semi-quantitative 5 × 5 (Appendix G assessment scales)
Supporting standards referenced	ISO/IEC 27005:2022, ISO 31000:2018, NIST CSF 2.0
Assessment period	07 – 08 September 2026
Assessment date	08 September 2026
Approval date	08 September 2026
Effective date	15 September 2026 (aligned to the CGI-POL policy pack effective date)
Review cadence	Quarterly for any risk rated High or Critical; annually for the full register; and on any material change or SEV1/SEV2 incident
Next scheduled review	15 December 2026
Next full annual review	15 September 2027
Risks in scope of this version	5 operational threat scenarios (R-001 to R-005)
Related documents	CGI-POL-001 to CGI-POL-005 (Startup Security Policy Pack v1.0); CGI-TRK-001 (Employee Policy Sign-off and Training Tracker)
Retention	Minimum 3 years, per CGI-POL-004 §4.2 (Confidential tier)

Scope

In scope. All information assets supporting the Cypher Group Inc. B2B SaaS project-management platform and the corporate environment: CloudCo production hosting, CodeCo source code repositories, OfficeCo, ChatCo, the PaymentsCo dashboard and payment metadata, the production database, employee endpoints (company-owned and personally owned), and the customer account data of approximately 200 SMB customers.

Out of scope for v1.0. Physical premises security beyond endpoint handling; financial and fraud risk not arising from an information security cause; third-party vendor risk assessed at supplier level (deferred to a dedicated Third-Party Risk Management programme); business continuity scenarios of non-security origin.

Time horizon. All likelihood scores express the probability of the event occurring **within a rolling 12-month period**.

Documented assumptions

These are stated so that a reviewer can challenge them rather than guess at them. Every one is simulated and set for the scenario.

#	Assumption	Used for
A-01	Annual recurring revenue is approximately **USD 3.6 million** (≈200 customers at an average contract value of ≈USD 18,000).	Calibrating the financial bands in the Impact scale to Cypher's actual size.
A-02	Headcount is 50, with an assumed annual attrition of 6 to 8 leavers.	Frequency basis for R-003 (insider / departing worker).
A-03	The CGI-POL pack is **approved but only 60% acknowledged** as at 05 September 2026 (CGI-TRK-001).	Applied as a **control effectiveness discount** — residual scores are not credited at full policy strength. See §5.
A-04	No backup, secure-development, vulnerability-management or cloud-configuration policy exists yet.	Explains why residual impact for R-002, R-004 and R-005 remains elevated. Recorded as control gaps CG-01 to CG-03.
A-05	Cypher Group holds **no cyber insurance** at the assessment date.	Basis of the Transfer element in the R-002 treatment.
A-06	Cypher Group is a **processor** under GDPR for customer personal data and a **controller** for employee data (CGI-POL-004 §4.5.4).	Regulatory dimension of the Impact scale.

1. Risk scoring legend (read this before the register)

The register is only defensible if a second assessor, given the same facts, would produce the same scores. That is what these anchored scales are for. Bare "High / Medium / Low" is not auditable; a number with a written anchor is.

1.1 Likelihood scale (probability of occurrence within 12 months)

Score	Label	Probability band	Frequency anchor	Evidence anchor
1	Rare	< 5%	Expected no more than once in 20+ years	No known occurrence in comparable SaaS organisations; strong preventive control verified as operating
2	Unlikely	5% – 20%	Roughly once in 5 to 20 years	Occurs occasionally in the sector; effective preventive controls verified in place at Cypher
3	Possible	20% – 50%	Roughly once in 2 to 5 years	Occurs regularly in the sector; Cypher has partial control coverage or a known residual weakness
4	Likely	50% – 80%	Expected at least once in the period	Common in the sector; a known, unmitigated weakness exists at Cypher
5	Almost Certain	> 80%	Expected one or more times in the period	Already occurring, actively targeted, or an exploitable weakness is confirmed present

1.2 Impact scale (worst credible single-event consequence)

Score the **highest** dimension reached — impact is not averaged across columns. Financial bands are calibrated to assumption A-01 (≈USD 3.6M ARR).

Score	Label	Financial	Regulatory / Legal	Customer & Contractual	Operational	Reputational
1	Insignificant	< USD 10k (< 0.3% ARR)	None	No customer aware; no notification	< 1 hour service disruption	Internal awareness only
2	Minor	USD 10k – 50k (0.3% – 1.4% ARR)	Internal finding only; no external report	A single customer informed; no contractual breach	1 – 4 hours disruption	Limited internal or single-customer concern
3	Moderate	USD 50k – 250k (1.4% – 7% ARR)	Reportable personal data breach under GDPR Art. 33; no fine expected	Multiple customers notified; some churn; one deal lost at security review	4 – 24 hours disruption or SLA breach	Industry or local press; questions in sales cycles
4	Major	USD 250k – 1M (7% – 28% ARR)	Regulatory investigation; GDPR Art. 33 **and** Art. 34 notification to individuals; fine plausible	Mass customer notification; material churn; contractual penalties invoked	1 – 3 days disruption	Trade press coverage; named in breach reporting
5	Severe	> USD 1M (> 28% ARR)	Fine at the GDPR 2% or 4% turnover tier; enforcement action	Contract terminations at scale; loss of ability to sell to enterprise buyers	> 3 days disruption or unrecoverable data loss	National coverage; existential reputational damage

1.3 Risk score calculation

> **Risk Score = Likelihood × Impact**, producing a value from 1 to 25. Calculated twice: **inherent** (controls assumed absent) and **residual** (existing, verified controls credited).

1.4 Qualitative risk thresholds

Score range	Rating	Meaning	Acceptance authority	Mandatory review cadence
1 – 4	**Low**	Tolerable. Manage through routine operations.	Department Head	Annual
5 – 9	**Medium**	Tolerable with active management and a named owner.	Chief Technology Officer	Semi-annual
10 – 14	**High**	Not tolerable without a funded, dated treatment plan.	Chief Executive Officer	Quarterly
15 – 25	**Critical**	Not tolerable. Requires immediate treatment and executive visibility.	CEO, with Board notification	Quarterly, and on any material change

Achievable score set. A 5 × 5 multiplicative model can only produce: 1, 2, 3, 4, 5, 6, 8, 9, 10, 12, 15, 16, 20, 25. The bands above are drawn so that every achievable value falls into exactly one band, with no ambiguous boundary. *(Range compression is the standard criticism of 5 × 5 matrices — knowing that, and stating it, is what makes the model defensible rather than naive. See §7 Limitations.)*

1.5 Risk treatment strategy definitions

Strategy	Definition	When it is the right answer
Mitigate	Reduce likelihood, impact or both by implementing or strengthening controls.	The activity is necessary and the risk can be economically reduced.

Strategy	Definition	When it is the right answer
Transfer	Shift financial or operational consequence to a third party via insurance or contract. Note that **reputational and regulatory liability cannot be transferred**.	Residual financial exposure remains material after mitigation.
Avoid	Stop, do not start, or redesign the activity that creates the risk.	The risk is disproportionate to the business value of the activity.
Accept	Formally retain the risk, by a named owner with the authority to do so, with justification, compensating controls and an expiry date.	Residual risk is within appetite, or treatment cost exceeds the risk reduction.

Accepted risk is not ignored risk. An acceptance without a named accepting owner, a documented justification and an expiry date is not an acceptance — it is an undocumented gap, and it is the finding auditors write up most often.

---

2. THE MASTER RISK REGISTER

One value per cell. No merged cells. Pastes cleanly into Google Sheets or Excel. This table is wide — scroll horizontally, or open the sortable CSV version.

R-001

Field	Value
Risk ID	R-001
Target Asset & Vulnerability	OfficeCo, ChatCo and CodeCo user accounts (Confidential data). Vulnerability: human susceptibility to credential-harvesting, compounded by relay-able authenticator-app one-time codes on standard accounts and only 60% policy acknowledgement recorded in CGI-TRK-001.
Threat Description	An external financially motivated attacker sends a credential-harvesting email impersonating OfficeCo to Cypher Group personnel; a user enters their password and one-time code into an attacker-in-the-middle proxy, resulting in session takeover of a corporate account, leading to unauthorised access to Confidential customer correspondence, business email compromise against Finance, and attempted lateral movement toward CodeCo and CloudCo.
Inherent Likelihood (1-5)	5
Inherent Impact (1-5)	4
Total Inherent Risk Score (Likelihood x Impact)	20
Mitigating Controls (Cross-referenced to Project 1 policies)	CGI-POL-002 §4.3.1 MFA mandated on OfficeCo, ChatCo, CodeCo, CloudCo, PaymentsCo and the production database; CGI-POL-002 §4.3.3 phishing-resistant FIDO2/WebAuthn or device-bound passkey mandated for all privileged accounts; CGI-POL-002 §4.3.4 passkey-first factor preference for standard accounts; CGI-POL-002 §4.3.5 SMS and voice prohibited as MFA factors; CGI-POL-002 §4.3.7 unsolicited MFA prompts reportable within one hour; CGI-POL-002 §4.1.5 and §4.1.6 password uniqueness and breach-list screening; CGI-POL-002 §4.2.1 credentials held only in the password manager; CGI-POL-002 §4.6.1 SSO through OfficeCo to centralise revocation; CGI-POL-002 §4.6.2 lockout after 10 failed attempts; CGI-POL-001 §4.7.3 suspected phishing forwarded, not interacted with; CGI-POL-001 §4.3.1 credential sharing prohibited; CGI-POL-003 §4.3.6 security awareness induction within 10 business days; CGI-POL-005 §5.2.2 one-hour reporting obligation; CGI-POL-005 §5.4 SEV2 acknowledgement within 30 minutes and containment within 8 hours.
Residual Likelihood (1-5)	2
Residual Impact (1-5)	3
Total Residual Risk Score (Likelihood x Impact)	6
Risk Treatment Strategy (Mitigate, Accept, Transfer, Avoid)	Mitigate
Action Owner (Job Title)	IT Operations Manager

R-002

Field	Value
Risk ID	R-002
Target Asset & Vulnerability	Employee endpoints, both company-owned and personally owned under the BYOD provisions of CGI-POL-001 §4.4, and any network-reachable corporate file store. Vulnerability: operating system and browser patches permitted to lag by up to 14 days; no documented backup or restore-testing obligation exists anywhere in the CGI-POL pack (control gap CG-01).
Threat Description	A ransomware affiliate delivers a loader through a malicious document or a drive-by exploit against an unpatched browser on a Cypher Group workstation, resulting in encryption of local and synchronised corporate data and attempted enumeration of reachable network shares and cloud storage, leading to loss of working data, extortion demand, service degradation for approximately 200 SMB customers and an unquantified recovery time because no restore has ever been tested.
Inherent Likelihood (1-5)	4
Inherent Impact (1-5)	5
Total Inherent Risk Score (Likelihood x Impact)	20
Mitigating Controls (Cross-referenced to Project 1 policies)	CGI-POL-001 §4.4.3 operating system and browser security updates applied within 14 calendar days of release; CGI-POL-001 §4.4.1 full-disk encryption mandatory on every device; CGI-POL-001 §4.4.2 automatic screen lock at 10 minutes; CGI-POL-001 §4.4.4 jailbroken or rooted devices prohibited; CGI-POL-001 §4.2.3 prohibition on disabling endpoint protection, disk encryption or logging; CGI-POL-001 §4.6.2 prohibition on unlicensed or untrusted software; CGI-POL-002 §4.4.1 separate administrative accounts, not used for email or browsing, so an infected user session holds no infrastructure rights; CGI-POL-003 §4.1.1 least privilege and §4.2.1 role profiles excluding Engineering from CloudCo production; CGI-POL-004 §4.2 encryption at rest required for Confidential and Restricted data; CGI-POL-005 §5.4 SEV1 acknowledgement within 15 minutes and containment within 4 hours; CGI-POL-005 §5.5 defined contain, eradicate and recover sequence with a timestamped decision log.
Residual Likelihood (1-5)	2
Residual Impact (1-5)	4
Total Residual Risk Score (Likelihood x Impact)	8
Risk Treatment Strategy (Mitigate, Accept, Transfer, Avoid)	Mitigate + Transfer
Action Owner (Job Title)	IT Operations Manager

R-003

Field	Value
Risk ID	R-003
Target Asset & Vulnerability	Customer account data, payment metadata and source code (Confidential and Restricted under CGI-POL-004 §4.1.1). Vulnerability: a resigning employee retains legitimate access during the notice period, and monitoring under CGI-POL-001 §4.10.1 is metadata-level only, with no data loss prevention tooling deployed (control gap CG-05).
Threat Description	A departing employee, acting on commercial motive before their effective leaving date, uses their legitimate role-profile access to export customer account records and internal documentation to a personal cloud storage account and a removable drive, resulting in unauthorised extraction of Restricted aggregated personal data, leading to a notifiable personal data breach under GDPR Article 33, contractual breach with affected customers, and potential competitive harm.
Inherent Likelihood (1-5)	3
Inherent Impact (1-5)	4

Field	Value
Total Inherent Risk Score (Likelihood x Impact)	12
Mitigating Controls (Cross-referenced to Project 1 policies)	CGI-POL-003 §4.5.1 immediate notification to IT and the CTO on resignation or termination decision; CGI-POL-003 §4.5.2 all access revoked within four hours of the effective termination time; CGI-POL-003 §4.5.3 involuntary terminations revoked simultaneously with the notification meeting; CGI-POL-003 §4.5.4 shared credentials rotated within four hours; CGI-POL-003 §4.5.5 API keys, deploy keys and personal access tokens rotated within five business days; CGI-POL-003 §4.5.6 accounts suspended and preserved for 90 days rather than deleted, protecting investigative evidence; CGI-POL-003 §4.5.9 mandatory evidenced offboarding checklist; CGI-POL-003 §4.7.1 quarterly privileged access review and §4.7.3 monthly orphaned account reconciliation; CGI-POL-003 §4.1.1 and §4.1.2 least privilege and need to know; CGI-POL-003 §4.2.1 role profiles excluding Sales and Customer Success from source code, CloudCo and PaymentsCo; CGI-POL-001 §4.11.2 prohibition on transferring company information to personal accounts or storage at any time; CGI-POL-001 §4.8.1 removable media prohibited for Confidential and Restricted data without written CTO approval; CGI-POL-001 §4.10 monitoring notice, which is the legal basis that makes authentication and file-access monitoring usable as a detective control; CGI-POL-004 §4.2 Handling Matrix, prohibiting Restricted data on removable media outright and requiring data owner plus CTO approval for external sharing; CGI-POL-004 §4.1.3 aggregation rule reclassifying a bulk customer export as Restricted.
Residual Likelihood (1-5)	2
Residual Impact (1-5)	3
Total Residual Risk Score (Likelihood x Impact)	6
Risk Treatment Strategy (Mitigate, Accept, Transfer, Avoid)	Mitigate
Action Owner (Job Title)	Head of People and Operations

R-004

Field	Value
Risk ID	R-004
Target Asset & Vulnerability	The internet-facing production application programming interface (API) of the Cypher Group SaaS platform, and the multi-tenant production database behind it. Vulnerability: no secure development, code review, change management or vulnerability management policy exists in the CGI-POL pack (control gap CG-02), so authorisation logic is unverified and no scanning cadence is mandated.
Threat Description	An unauthenticated or low-privilege external attacker probes the production API and discovers a broken object-level authorisation flaw allowing customer identifiers to be manipulated across tenant boundaries, resulting in the ability to enumerate and retrieve the account data of customers other than their own, leading to a cross-tenant personal data breach affecting a substantial share of the approximately 200 customer base, mandatory notification under GDPR Articles 33 and 34, and loss of the enterprise deals currently held at security review.
Inherent Likelihood (1-5)	4
Inherent Impact (1-5)	5
Total Inherent Risk Score (Likelihood x Impact)	20

Field	Value
Mitigating Controls (Cross-referenced to Project 1 policies)	CGI-POL-002 §4.5.1 service account credentials and API keys rotated at least every 180 days and immediately on suspected compromise; CGI-POL-002 §4.5.2 CodeCo secret scanning and push protection maintained on all repositories; CGI-POL-002 §4.5.3 any committed secret treated as compromised and rotated, not merely removed from history; CGI-POL-002 §4.5.4 service accounts granted minimum permissions with a named human owner; CGI-POL-004 §4.2 encryption in transit required for every classification above Public; CGI-POL-004 §4.1.4 payment card numbers never stored by Cypher Group, limiting the maximum data at risk; CGI-POL-003 §4.2.1 role profiles restricting production database access to on-call Engineering only; CGI-POL-005 §5.1.1 mandatory reporting of unexpected system behaviour, unexplained changes or new accounts; CGI-POL-005 §5.4 SEV1 classification with four-hour containment target; CGI-POL-005 §5.6.3 defined GDPR 72-hour supervisory authority notification path. **Assessed as materially insufficient — see control gap CG-02.**
Residual Likelihood (1-5)	3
Residual Impact (1-5)	4
Total Residual Risk Score (Likelihood x Impact)	12
Risk Treatment Strategy (Mitigate, Accept, Transfer, Avoid)	Mitigate
Action Owner (Job Title)	Chief Technology Officer

R-005

Field	Value
Risk ID	R-005
Target Asset & Vulnerability	CloudCo production environment: Simple Storage Service (S3) buckets holding customer data exports and backups, security group network rules, and Identity and Access Management (IAM) policies. Vulnerability: the policy pack governs *who* may change CloudCo but defines no secure baseline for *how* it must be configured, and no automated configuration monitoring or drift detection exists (control gap CG-03).
Threat Description	An administrator with legitimate CloudCo access misconfigures an S3 bucket policy or access control list while troubleshooting, or provisions a new bucket without the account-level public access block, resulting in customer account data and database exports becoming readable from the public internet without authentication, leading to indexed exposure of Restricted aggregated personal data, discovery by a third party or researcher rather than by Cypher Group, notification obligations under GDPR Articles 33 and 34, and severe reputational damage of the category most commonly reported in the technology press.
Inherent Likelihood (1-5)	4
Inherent Impact (1-5)	5
Total Inherent Risk Score (Likelihood x Impact)	20

Field	Value
Mitigating Controls (Cross-referenced to Project 1 policies)	CGI-POL-004 §4.2 Handling Matrix requiring encryption at rest for Confidential and Restricted data, restricting Restricted data to named approved systems listed by the data owner, and requiring named-individual access approved by the data owner and the CTO; CGI-POL-004 §4.1.3 aggregation rule classifying bulk customer exports as Restricted and therefore subject to the strictest handling row; CGI-POL-002 §4.3.1 MFA mandated on CloudCo; CGI-POL-002 §4.3.3 phishing-resistant factor mandated for the privileged CloudCo accounts that can alter bucket policy; CGI-POL-002 §4.4.1 separate administrative accounts; CGI-POL-002 §4.4.3 CloudCo root protected by hardware MFA, sealed under CTO control, with alerting on any use; CGI-POL-003 §4.2.1 role profiles excluding non-on-call Engineering, Sales, Finance and Customer Success from CloudCo production; CGI-POL-003 §4.7.1 quarterly privileged access review with evidenced approval or removal decisions; CGI-POL-003 §4.1.5 mandatory ticket for every access change, preserving the audit trail; CGI-POL-001 §4.2.3 prohibition on circumventing or degrading security controls including logging; CGI-POL-005 §5.1.1 mandatory reporting of unexplained configuration change. **Preventive coverage only — no detective control exists. See control gap CG-03.**
Residual Likelihood (1-5)	3
Residual Impact (1-5)	4
Total Residual Risk Score (Likelihood x Impact)	12
Risk Treatment Strategy (Mitigate, Accept, Transfer, Avoid)	Mitigate
Action Owner (Job Title)	Chief Technology Officer

3. Residual scoring rationale and control effectiveness

The register above records *what* the scores are. This section records *why* — which is the part an auditor or an interviewer will actually interrogate. Every drop from inherent to residual is justified here, and every drop that did **not** happen is explained.

R-001

Field	Value
Risk ID	R-001
Inherent	20
Rating	Critical
Residual	6
Rating	Medium
Score reduction	−14
Risk owner (accountable business role)	Chief Technology Officer
Justification for the residual score	**Likelihood 5 → 2.** Phishing attempts against a 50-person SaaS company are continuous, so inherent likelihood is Almost Certain. CGI-POL-002 §4.3.3 makes privileged accounts cryptographically unphishable — a FIDO2 authenticator will not release a credential to a proxy domain, so the highest-value path is closed by design rather than by vigilance. Likelihood does not reach 1 because §4.3.4 still permits authenticator-app one-time codes on standard accounts, and those remain relay-able. **Impact 4 → 3.** A standard-account compromise no longer reaches infrastructure, because §4.4.1 separates administrative accounts and CGI-POL-003 §4.2.1 role profiles bound what any one account can see. The one-hour reporting duty (CGI-POL-005 §5.2.2) plus SSO revocation (§4.6.1) shortens dwell time from weeks to hours. Impact does not fall below 3 because a compromised mailbox still contains Confidential customer correspondence.

R-002

Field	Value
Risk ID	R-002
Inherent	20
Rating	Critical
Residual	8
Rating	Medium
Score reduction	−12
Risk owner (accountable business role)	Chief Technology Officer
Justification for the residual score	**Likelihood 4 → 2.** The 14-day patch obligation (CGI-POL-001 §4.4.3), the prohibition on disabling endpoint protection (§4.2.3), the prohibition on untrusted software (§4.6.2) and the separation of administrative accounts (CGI-POL-002 §4.4.1) together remove the common delivery and escalation paths. **Impact 5 → 4, deliberately only one point.** This is the most important judgement in the register. Full-disk encryption protects data at rest against device theft but does nothing against ransomware, which encrypts data the logged-in user can already read. Least privilege limits spread. But **the CGI-POL pack contains no backup or restore-testing obligation at all**, so recovery time remains unevidenced and an unrecoverable-data scenario cannot be excluded. Crediting a lower impact here would be crediting a control that does not exist. Residual impact falls to 4, not 3, and stays there until CG-01 is closed.

R-003

Field	Value
Risk ID	R-003
Inherent	12
Rating	High
Residual	6
Rating	Medium
Score reduction	−6
Risk owner (accountable business role)	Head of Customer Success (data owner for customer account data)
Justification for the residual score	**Likelihood 3 → 2.** The four-hour revocation window (CGI-POL-003 §4.5.2), simultaneous revocation on involuntary termination (§4.5.3), monthly orphaned-account reconciliation (§4.7.3) and the explicit monitoring notice (CGI-POL-001 §4.10) collectively remove the post-departure window and create a credible deterrent. Likelihood cannot reach 1 because the pre-departure window, during which access is entirely legitimate, cannot be closed by an access control. **Impact 4 → 3.** Role profiles (§4.2.1) cap what any single leaver can reach, and the aggregation rule (CGI-POL-004 §4.1.3) places bulk exports behind named-list approval by the data owner and the CTO. Impact does not fall further because no data loss prevention tooling exists (CG-05), so detection of an exfiltration in progress is not assured — it is reconstructed after the fact from metadata.

R-004

Field	Value
Risk ID	R-004
Inherent	20
Rating	Critical
Residual	12
Rating	**High**
Score reduction	−8
Risk owner (accountable business role)	Chief Technology Officer

Field	Value
Justification for the residual score	**Likelihood 4 → 3 only.** The Project 1 controls address *credential-borne* API abuse — key rotation, secret scanning, least-privilege service accounts. They do not address *authorisation logic* defects, which is the actual vulnerability class in this scenario. No policy in the pack requires code review, security testing, dependency scanning or a vulnerability remediation SLA (CG-02). **Impact 5 → 4.** Encryption in transit, the exclusion of card numbers from Cypher's systems (CGI-POL-004 §4.1.4) and the SEV1 four-hour containment target reduce both the maximum data at risk and the exposure window. **This risk remains High after treatment and is the single strongest argument in the register for the next tranche of investment.** Recording that honestly is more valuable than manufacturing a green score.

R-005

Field	Value
Risk ID	R-005
Inherent	20
Rating	Critical
Residual	12
Rating	**High**
Score reduction	−8
Risk owner (accountable business role)	Chief Technology Officer
Justification for the residual score	**Likelihood 4 → 3 only.** Quarterly privileged access review (CGI-POL-003 §4.7.1), the role profiles that exclude most of the company from CloudCo production, and mandatory ticketing (§4.1.5) reduce the number of hands able to cause the misconfiguration and preserve an audit trail. But every one of these is a *preventive administrative* control acting on people. **There is no technical guardrail and no detective control** — no account-level S3 Block Public Access enforcement, no AWS Config rules, no drift alerting (CG-03). A misconfiguration made by an authorised administrator would therefore still occur and would not be detected internally. **Impact 5 → 4.** The encryption-at-rest requirement and the named-approved-systems restriction in CGI-POL-004 §4.2 limit both the readability and the concentration of exposed data.

Control effectiveness caveat (applies to the whole register)

Every residual score above is credited at **partial** rather than full control strength, for one documented reason: CGI-TRK-001 records the policy pack as **60% acknowledged** as at 05 September 2026, with security awareness training at 60% completion and MFA coverage at 80%.

A policy that is approved but not acknowledged, and a control that is mandated but not technically enforced, do not reduce residual risk at full value. When the tracker reaches 100% acknowledgement, 100% MFA coverage and a completed awareness programme, this register shall be re-scored, and the expected residual positions are recorded in §4 as target residual scores.

This is the sentence to be able to say out loud: "I score the control that is operating, not the control that is written."

---

4. Risk treatment plan

TP-01

Field	Value
Treatment ID	TP-01
Risk ID	R-001
Strategy	Mitigate

Field	Value
Action	Issue FIDO2 hardware security keys or enforce device-bound passkeys for all 50 personnel, removing authenticator-app one-time codes as an accepted factor for standard accounts.
Control type	Preventive
Existing policy anchor	CGI-POL-002 §4.3.3, §4.3.4
Estimated cost (USD)	2,500
Action owner (job title)	IT Operations Manager
Target completion	31 October 2026
Target residual score	3

TP-02

Field	Value
Treatment ID	TP-02
Risk ID	R-001
Strategy	Mitigate
Action	Drive CGI-TRK-001 to 100% policy acknowledgement and 100% security awareness training completion; introduce quarterly simulated phishing with reporting-rate as the metric, not click-rate alone.
Control type	Preventive, Detective
Existing policy anchor	CGI-POL-001 §6.2; CGI-POL-003 §4.3.6
Estimated cost (USD)	1,800
Action owner (job title)	Head of People and Operations
Target completion	30 November 2026
Target residual score	3

TP-03

Field	Value
Treatment ID	TP-03
Risk ID	R-002
Strategy	Mitigate
Action	Author and approve **CGI-POL-006 Backup and Recovery Policy** mandating defined RPO and RTO, immutable or offline backup copies, and a restore test performed and evidenced at least quarterly. Closes CG-01.
Control type	Corrective
Existing policy anchor	New policy — gap CG-01
Estimated cost (USD)	0 (internal effort)
Action owner (job title)	Chief Technology Officer
Target completion	31 October 2026
Target residual score	4

TP-04

Field	Value
Treatment ID	TP-04
Risk ID	R-002
Strategy	**Transfer**

Field	Value
Action	Procure cyber insurance covering incident response costs, business interruption and extortion, with a limit informed by the Impact scale band 4 to 5. Note that reputational and regulatory liability are not transferable.
Control type	Financial
Existing policy anchor	Assumption A-05
Estimated cost (USD)	9,000 per annum
Action owner (job title)	Chief Executive Officer
Target completion	15 December 2026
Target residual score	6

TP-05

Field	Value
Treatment ID	TP-05
Risk ID	R-002
Strategy	Mitigate
Action	Deploy centrally managed endpoint detection and response with enforced patch compliance reporting, converting the 14-day patch obligation from a written duty into a measurable one.
Control type	Preventive, Detective
Existing policy anchor	CGI-POL-001 §4.4.3, §4.2.3
Estimated cost (USD)	4,200 per annum
Action owner (job title)	IT Operations Manager
Target completion	31 January 2027
Target residual score	6

TP-06

Field	Value
Treatment ID	TP-06
Risk ID	R-003
Strategy	Mitigate
Action	Enable OfficeCo and endpoint data loss prevention rules for bulk export of Confidential and Restricted data, and add an automated alert on large downloads by any account in a notice period. Closes CG-05.
Control type	Detective
Existing policy anchor	CGI-POL-001 §4.10.1; CGI-POL-004 §4.2
Estimated cost (USD)	2,400 per annum
Action owner (job title)	IT Operations Manager
Target completion	31 January 2027
Target residual score	4

TP-07

Field	Value
Treatment ID	TP-07
Risk ID	R-004
Strategy	Mitigate

Field	Value
Action	Author and approve **CGI-POL-007 Secure Development and Change Management Policy**, mandating peer code review, authorisation testing on every tenant-scoped endpoint, and segregation between development and production. Closes part of CG-02.
Control type	Preventive
Existing policy anchor	New policy — gap CG-02
Estimated cost (USD)	0 (internal effort)
Action owner (job title)	Chief Technology Officer
Target completion	30 November 2026
Target residual score	8

TP-08

Field	Value
Treatment ID	TP-08
Risk ID	R-004
Strategy	Mitigate
Action	Author and approve **CGI-POL-008 Vulnerability Management Policy** with remediation SLAs by severity; enable dependency scanning; commission an independent API penetration test with retest.
Control type	Preventive, Detective
Existing policy anchor	New policy — gap CG-02
Estimated cost (USD)	11,000
Action owner (job title)	Chief Technology Officer
Target completion	31 January 2027
Target residual score	6

TP-09

Field	Value
Treatment ID	TP-09
Risk ID	R-005
Strategy	Mitigate
Action	Enable CloudCo account-level S3 Block Public Access, apply a Service Control Policy preventing its removal, and enable AWS Config rules with alerting for public storage, unencrypted volumes and unrestricted security groups. Closes CG-03.
Control type	Preventive, Detective
Existing policy anchor	CGI-POL-004 §4.2
Estimated cost (USD)	1,200 per annum
Action owner (job title)	Chief Technology Officer
Target completion	30 November 2026
Target residual score	6

TP-10

Field	Value
Treatment ID	TP-10
Risk ID	R-005
Strategy	Mitigate

Field	Value
Action	Author a cloud configuration baseline standard aligned to the CIS Amazon Web Services Foundations Benchmark, and assess against it quarterly with evidenced results.
Control type	Preventive
Existing policy anchor	New standard — gap CG-03
Estimated cost (USD)	0 (internal effort)
Action owner (job title)	Chief Technology Officer
Target completion	28 February 2027
Target residual score	4

4.1 Formally accepted risk

Recorded here so that the register demonstrates all four treatment strategies, and because an acceptance that is not written down is not an acceptance.

Acceptance ID	Related risk	What is accepted	Justification	Compensating control	Accepting authority	Approval date	Expiry date	Review
ACC-001	R-001 (sub-scenario)	Continued use of SMS as an MFA factor by two named Finance users on the legacy billing portal, contrary to CGI-POL-002 §4.3.5. Carried forward from Exception Register EXC-001.	The legacy billing portal supports no alternative factor. Migration to a supporting platform is planned for Q1 2027. Removing access would halt customer invoicing.	Access limited to two named users; login alerting enabled; monthly access review; the accounts hold no Restricted data.	Priya Raman, Chief Technology Officer (Medium residual — within CTO acceptance authority per §1.4)	03 September 2026	03 March 2027	At expiry, or immediately on migration completion

4.2 Risk avoided by design

Avoidance ID	Risk avoided	Decision	Policy anchor
AVD-001	Storage, processing and breach of primary account numbers (payment card data), which would place Cypher Group in PCI DSS scope and raise the maximum credible impact of R-004 and R-005 to score 5.	Cypher Group does not store card numbers. All card data is held by PaymentsCo; Cypher retains payment metadata only. The activity that would create the risk is not performed.	CGI-POL-004 §4.1.4

4.3 Control gap register

Gaps identified during this assessment where the Project 1 policy pack provides no coverage. Each one caps how far a residual score can defensibly fall.

Gap ID	Gap	Risks affected	Consequence for scoring	Closure action
CG-01	No backup, recovery, RPO/RTO or restore-testing obligation anywhere in CGI-POL-001 to 005.	R-002	Residual impact held at 4; cannot fall to 3 without evidenced restore capability.	TP-03
CG-02	No secure development, code review, change management or vulnerability management policy.	R-004	Residual likelihood held at 3; the existing controls do not address authorisation logic defects.	TP-07, TP-08

Gap ID	Gap	Risks affected	Consequence for scoring	Closure action
CG-03	No cloud configuration baseline and no automated configuration monitoring or drift detection.	R-005	Residual likelihood held at 3; all coverage is preventive and administrative, with no detective control.	TP-09, TP-10
CG-04	Security awareness training is mandated at induction only (CGI-POL-003 §4.3.6); no recurring programme or simulation exists.	R-001, R-003	Contributes to the partial control-effectiveness discount applied across the register.	TP-02
CG-05	No data loss prevention tooling; monitoring under CGI-POL-001 §4.10.1 is metadata-level only.	R-003	Residual impact held at 3; exfiltration is reconstructed after the fact rather than interrupted.	TP-06

5. Key risk indicators

A register is a snapshot; key risk indicators are what tell you a score has moved before an incident does.

KRI ID	Indicator	Related risk	Source	Threshold (green / amber / red)	Reporting cadence	Owner
KRI-01	Percentage of accounts with a phishing-resistant MFA factor enrolled	R-001, R-005	CGI-POL-002 §6.2 quarterly MFA coverage report	≥ 95% / 80–94% / < 80%	Quarterly	IT Operations Manager
KRI-02	Policy acknowledgement rate across all personnel	R-001, R-003	CGI-TRK-001	100% / 90–99% / < 90%	Monthly	Head of People and Operations
KRI-03	Mean time to revoke all access after effective termination time	R-003	CGI-POL-003 §4.5.2 offboarding checklists	≤ 4 hours / 4–24 hours / > 24 hours	Quarterly	IT Operations Manager
KRI-04	Percentage of endpoints with security patches applied within 14 days	R-002	Endpoint management reporting (TP-05)	≥ 95% / 85–94% / < 85%	Monthly	IT Operations Manager
KRI-05	Number of CloudCo resources failing the configuration baseline	R-005	AWS Config (TP-09)	0 / 1–3 / > 3	Monthly	Chief Technology Officer
KRI-06	Count of orphaned accounts identified in the monthly reconciliation	R-003	CGI-POL-003 §4.7.3	0 / 1–2 / > 2	Monthly	IT Operations Manager
KRI-07	Open critical or high vulnerabilities past their remediation SLA	R-004	CGI-POL-008 once approved (TP-08)	0 / 1–2 / > 2	Monthly	Chief Technology Officer

6. Register summary

Metric	Value
Risks assessed	5

Metric	Value
Inherent: Critical	4 (R-001, R-002, R-004, R-005)
Inherent: High	1 (R-003)
Aggregate inherent score	92 of a possible 125
Mean inherent score	18.4 (Critical band)
Residual: High	2 (R-004, R-005)
Residual: Medium	3 (R-001, R-002, R-003)
Residual: Critical	0
Aggregate residual score	44
Mean residual score	8.8 (Medium band)
Total risk reduction attributable to the CGI-POL policy pack	48 points, a 52% reduction in aggregate exposure
Risks remaining above appetite (High or Critical)	2, both requiring CEO-level acceptance authority pending treatment
Treatment actions raised	10 (TP-01 to TP-10)
Estimated treatment cost, year one	USD 32,100
Control gaps identified	5 (CG-01 to CG-05)
New policies recommended	3 (CGI-POL-006 Backup and Recovery, CGI-POL-007 Secure Development and Change Management, CGI-POL-008 Vulnerability Management)

The single headline for leadership. *The policy pack approved on 01 September 2026 removes just over half of Cypher Group's assessed information security exposure at effectively zero direct cost. It does not touch two of the five scenarios, because it contains no controls governing how software is built or how cloud infrastructure is configured. Those two remain High and are where the next USD 32,000 should go.*

---

7. Methodology, limitations and honest caveats

Method. Semi-quantitative 5 × 5 assessment per NIST SP 800-30 Rev. 1, with likelihood and impact anchored to written definitions (§1.1, §1.2) so that scoring is reproducible between assessors. Risk = Likelihood × Impact, computed for inherent and residual states. Existing controls are credited only where they are documented in an approved policy and are technically or procedurally capable of operating.

Limitations, stated deliberately.

1. **Range compression.** A 5 × 5 multiplicative model cannot distinguish between a rare catastrophic event and a frequent moderate one that share a product. Both R-002 (4 × 5) and R-001 (5 × 4) score 20 inherent but demand different treatments. The written rationale in §3, not the number, carries the decision.
2. **Ordinal arithmetic.** Multiplying ordinal scales is mathematically improper — a 4 is not twice a 2. The scores rank and communicate; they do not measure. Where a real spending decision is at stake, this register should be supplemented by quantitative analysis (loss event frequency and loss magnitude as distributions, simulated) rather than relied upon alone.
3. **No internal incident history.** Likelihood estimates draw on sector frequency and on the observed control state at Cypher Group, not on Cypher's own incident data, because none exists. Estimates should be recalibrated once the incident register required by CGI-POL-005 §5.7.5 holds 12 months of data.
4. **Control effectiveness is asserted, not tested.** Residual scores credit controls as designed. No test of operating effectiveness has been performed. A control testing programme is the natural next assurance step, and until it exists every residual score should be read as an upper-bound claim.
5. **Scope.** Five operational scenarios only. This is not a complete enterprise risk assessment; supply chain, availability, regulatory-change and fraud scenarios are not covered in version 1.0.

Assurance statement. All content is simulated and was produced for portfolio demonstration. It has not been reviewed by a certification body, a CPA firm or legal counsel, and no certification or attestation is claimed or implied.

8. Approval

Role	Name (simulated)	Action	Date
Prepared by	O.S, GRC Analyst (engaged)	Assessment performed and register drafted	08 September 2026
Reviewed by	Priya Raman, Chief Technology Officer	Register owner; reviewed scoring and control mapping	08 September 2026
Approved by	Jerry Gold, Chief Executive Officer	Accepted the two residual High risks pending completion of TP-07 to TP-10	08 September 2026

Signature: _____ *Date:* _____

END OF REGISTER — CGI-RSK-001 v1.0. Prepared by O.S · Portfolio project 02.